

IDENTITY AND ACCESS MANAGEMENT (IAM) GOVERNANCE ARCHITECTURE

Policy Owner:	IT Governance
Author:	Morolake Bolarinwa
Version:	1.0 (Final)
Effective Date:	September 2026

1. EXECUTIVE SUMMARY & ZERO TRUST OBJECTIVES

Purpose: The purpose of this Identity and Access Management (IAM) Governance Architecture is to establish a secure, unified framework for managing user identities, authentication, and authorization across both on-premises and cloud environments.

Zero Trust Objectives:

- **Enforce Least Privilege:** Ensure users and service accounts are granted only the minimum level of access required to perform their authorized duties.
- **Assume Breach:** Implement continuous verification of identity and device health for every access request, regardless of the user's location or network.
- **Centralize Governance:** Establish a single control plane for identity lifecycle management, auditing, and access reviews across the enterprise.

Scope: This architecture applies to all internal employees, remote workforce members, contractors, and automated service accounts accessing corporate resources, applications, and infrastructure.

2. HYBRID IDENTITY ARCHITECTURE & SYNCHRONIZATION

To support legacy on-premises applications while enabling modern cloud-based workflows, the enterprise relies on a securely governed Hybrid Identity Architecture.

- **On-Premises Foundation:** A **Windows Server 2022 Domain Controller** serves as the authoritative source for local directory services. User provisioning, password complexity requirements, and baseline endpoint security configurations are strictly governed through Active Directory Group Policy Objects (GPOs).
- **Cloud Synchronization:** Identities are synchronized from the on-premises Active Directory to **Microsoft Entra ID** (formerly Azure AD) utilizing Microsoft Entra Connect. This establishes a unified hybrid identity, allowing users to leverage Single Sign-On (SSO) across all enterprise and third-party SaaS applications.

- **Governance Boundary:** While local AD manages physical on-premises resource access, Entra ID serves as the ultimate governance boundary for all cloud resources, establishing a clear separation of duties. Cloud-based Role-Based Access Control (RBAC) is enforced exclusively through Entra ID, mitigating the risk of lateral movement from on-premises compromise to cloud infrastructure.

3. CONDITIONAL ACCESS & AUTHENTICATION POLICIES

To enforce the Zero Trust 'Assume Breach' methodology, Microsoft Entra ID Conditional Access policies act as the primary security gateway for all enterprise resources. The following baseline policies are enforced globally:

- **Universal MFA Enforcement:** Multi-Factor Authentication (MFA) is strictly required for all internal and external user access to Microsoft 365 and connected SaaS applications, prioritizing phishing-resistant methods (e.g., Microsoft Authenticator, FIDO2 keys).
- **Legacy Authentication Blocking:** All legacy authentication protocols (e.g., IMAP, POP3, older Office clients) are completely blocked to eliminate vulnerabilities to password spray and brute-force attacks.
- **Risk-Based Access Controls:** Integration with Entra ID Protection evaluates sign-in risk in real-time. High-risk sign-ins (e.g., originating from anonymous IP addresses or impossible travel scenarios) automatically trigger a strict block or mandate a secure password reset before granting access.

4. PRIVILEGED IDENTITY MANAGEMENT (PIM) STRATEGY

Standing administrative privileges expose the hybrid environment to significant risk if an account is compromised. To mitigate this, Microsoft Entra Privileged Identity Management (PIM) is deployed to govern all elevated access.

- **Just-In-Time (JIT) Access:** Administrators operate with standard user rights by default. Elevated roles (e.g., Global Administrator, Security Administrator, Exchange Administrator) are only activated on an as-needed basis for a predefined, time-bound window (maximum 4 hours).
- **Approval Workflows & Verification:** Activation of critical infrastructure roles requires an explicit business justification ticketing number, forced MFA verification, and secondary approval from a designated IT Governance owner.
- **Periodic Access Reviews:** Automated quarterly Access Reviews are configured within PIM to audit all active administrative assignments. This ensures role retention remains justified and dormant administrative accounts are systematically offboarded.

5. CONTINUOUS MONITORING & AUDIT (KQL & SENTINEL)

To ensure the effectiveness of the IAM architecture and rapidly detect identity-based threats, all authentication telemetry is continuously monitored.

- **Log Ingestion:** Microsoft Entra ID Sign-in, Audit, and Non-Interactive user logs are natively integrated and forwarded to **Microsoft Sentinel (SIEM)** for centralized analysis and long-term retention.
- **Threat Hunting & KQL:** Security analysts utilize Kusto Query Language (KQL) within Sentinel to actively hunt for identity anomalies. Custom analytics rules are deployed to trigger automated alerts for:
 - Concurrent logins from geographically distant locations (Impossible Travel).
 - Repeated MFA failures followed by a successful login.
 - Unauthorized activation or modification of Privileged Identity Management (PIM) roles.
- **Incident Escalation:** High-fidelity identity alerts generated in Sentinel are immediately escalated to the Security Operations Center (SOC) for triage, containment (e.g., revoking active sessions, forcing password resets), and remediation.